LAPORAN INVESTIGASI BUG TEKNIKAL & AUDIT DATABASE

DEADLOCK LOGIN PADA AKUN PENGGUNA BERSTATUS 'REMOVED' (EVMOTO USER MOBILE)

NOMOR DOKUMEN:	**EVM-BUG-REP-2026-10-005**	**SEVERITY LEVEL:**	**P0 - CRITICAL BLOCKER**
LEAD QA AUDITOR:	Bhagus Arif Prayogo (Senior QA Engineer)	**ENVIRONMENT:**	Staging / Development (Golang Backend)
TARGET SISTEM:	EvMoto User App & Backend Auth API	**TANGGAL INSIDEN:**	29 Oktober 2026 (Live Audit Verification)
DITUJUKAN KEPADA:	**Lead Backend Developer, Lead Mobile Flutter, Engineering Manager**		

1. RINGKASAN EKSEKUTIF & DESKRIPSI INSIDEN

Ditemukan anomali kritis (P0 Blocker) pada alur otentikasi aplikasi EvMoto Mobile User di mana pengguna yang mencoba melakukan LOGIN justru mendapatkan notifikasi snackbar error: 'This phone number is already registered'. Investigasi teknikal mendalam membuktikan bahwa akun tersebut sebelumnya telah melakukan pengajuan 'Hapus Akun' (Account Cancellation). Backend Golang menerapkan mekanisme Soft Delete (state = 3 / Removed), namun pada endpoint login /account/base/user/captchaLogin, ketiadaan penanganan siklus hidup akun menyebabkan backend salah mengasumsikan pengguna sebagai pendaftar baru (auto-register), yang kemudian menabrak constraint unik di database. Hal ini menciptakan kondisi DEADLOCK TOTAL: Pengguna tidak dapat Login dan tidak dapat Mendaftar Ulang.

2. BUKTI FORENSIK & VERIFIKASI DATABASE STAGING

Hasil query langsung pada tabel t_user dan tabel userExit di Admin Console (https://evmotoadmin.justkidding.app):

Field Database	Nilai Data Riil Terverifikasi	Interpretasi Status Sistem
Nomor Telepon Uji	6282146627896 (Input: 82146627896)	Nomor valid terdaftar di Staging
User ID Internal	615	Primary key unik pada tabel t_user
Nama / Nickname	tes	Profil pengguna saat registrasi
Cabang Operasional	Singapore - editedx	Branch ID staging terkait
Waktu Registrasi	2026-10-29 03:27:20 UTC (10:27:20 WIB)	Akun dibuat hari ini (baru saja)
Waktu Hapus Akun	2026-10-29 10:28:46 WIB (userExit ID: 15)	Pengajuan Hapus Akun via menu profil
Status Akun (t_user.state)	**3 (Removed)**	**Soft-deleted flag (Ditolak oleh auth aktif)**
Status userExit	Pending (-) / Belum di-cleared admin	Antrean penghapusan akun masih aktif

3. BUKTI FORENSIK JARINGAN & RESPONS API BACKEND

Reproduksi teknikal dilakukan menggunakan payload HTTP identik yang dikirimkan oleh Mobile App ke server Golang (https://evmotodev.justkidding.app). Berikut bukti respons jaringan secara transparan:

```
POST https://evmotodev.justkidding.app/account/base/queryCaptcha (Step 1: Request OTP)
Payload : {"phone": "82146627896", "type": 1}
Response: HTTP 200 OK | {"code": 200, "msg": "SUCCESS", "data": {}}
--> Kode OTP Dev '1234' berhasil diterbitkan tanpa error.
```

```
POST https://evmotodev.justkidding.app/account/base/user/captchaLogin (Step 2: Submit Login)
Payload : {"phone": "82146627896", "code": "1234"}
Response: HTTP 200 OK | {"code": 500, "msg": "This phone number is already registered", "data": {}}
[!] CRITICAL: Backend mengembalikan kode 500 dengan pesan 'This phone number is already registered'.
--> Mobile App menangkap msg tersebut dan memunculkannya ke snackbar pengguna.
```

4. REKONSTRUKSI AKAR MASALAH (ROOT CAUSE ANALYSIS)

Mengapa alur Login justru memicu pesan 'This phone number is already registered'?

1. Desain Endpoint Hybrid (Login / Auto-Register):
   Endpoint /account/base/user/captchaLogin didesain melayani login sekaligus registrasi otomatis bagi pengguna baru.
2. Tahap Pengecekan Akun Aktif:
   Backend mengeksekusi query: SELECT * FROM t_user WHERE phone = '6282146627896' AND state = 1 (Normal/Active).
   Karena User ID 615 memiliki state = 3 (Removed), query ini menghasilkan NIL (Tidak Ditemukan Akun Aktif).
3. Fallback Keliru ke Alur Pendaftaran Baru:
   Karena akun aktif tidak ditemukan, backend berasumsi bahwa nomor ini adalah calon user baru yang hendak mendaftar.
4. Benturan Constraint Unik Database (Unique Key Conflict):
   Saat backend hendak mengeksekusi pembuatan record user baru, database memeriksa keberadaan nomor telepon tanpa memfilter state (SELECT COUNT(*) FROM t_user WHERE phone = '6282146627896'). Database menemukan record User ID 615 masih ada di tabel t_user!
5. Lemparan Error 500 ke Aplikasi:
   Backend Golang gagal melakukan insert dan melempar pesan validasi duplikat: 'This phone number is already registered'.

KONDISI DEADLOCK PENGGUNA (USER STRANDED CONDITION):

- Mau LOGIN : DITOLAK karena akun berstatus 'Removed' (State = 3), diarahkan ke auto-register.
- Mau REGISTER: DITOLAK karena nomor HP masih bersarang di tabel t_user (State = 3 belum dihapus tuntas).
- Kesimpulan : Pengguna selamanya terkunci di luar aplikasi tanpa pesan solusi yang dapat dimengerti.

5. KORELASI DENGAN LAPORAN AUDIT CELAH #1 (VOUCHER FARMING)

Temuan ini berkaitan erat dengan Celah Nomor 1 pada Dokumen Audit Keamanan EVM-SEC-REP-2026-10-004 ('Kupon user baru bisa diambil berulang cukup dengan hapus akun lalu daftar ulang'):
- Tim developer sebelumnya mengonfirmasi bahwa penghapusan akun berpotensi disalahgunakan jika database membersihkan riwayat pendaftaran.
- Fakta teknikal hari ini membuktikan bahwa saat ini backend mengadopsi mekanisme Soft Delete (state = 3), namun arsitektur siklus hidup akun (Account Lifecycle Management) belum selesai diimplementasikan secara tuntas.
- Hasilnya, sistem terjebak di tengah-tengah: berniat mencegah re-registrasi liar, namun justru mengunci pengguna sah dalam status error permanen tanpa alur reaktivasi akun yang semestinya.

6. RENCANA TINDAKAN PERBAIKAN TEKNIKAL (ACTION ITEMS)

A. Rekomendasi untuk Tim Backend (Golang Developer):

1. Penanganan State Removed di Endpoint captchaLogin:
   Tambahkan pengecekan eksplisit terhadap akun berstatus state = 3. Jika pengguna dengan status 'Removed' menginput OTP yang benar:
   - Opsi 1 (Reaktivasi): Kembalikan response khusus (misal: code: 200, status: 'ACCOUNT_DEACTIVATED') dan tawarkan opsi reaktivasi akun di UI.
   - Opsi 2 (Pemberitahuan Khusus): Jangan melempar pesan 'This phone number is already registered', melainkan: 'Akun Anda sedang dalam proses penghapusan. Hubungi Pusat Bantuan untuk memulihkan akun.'.
2. Pemisahan Routing Login vs Registrasi:
   Hindari perilaku hybrid yang menebak niat pengguna. Alur Registrasi harus melewati rute khusus POST /account/base/user, sedangkan Login harus melewati rute murni POST /account/base/user/login yang secara tegas memeriksa status akun.
3. Anonymization / Hash Phone pada Penghapusan Akun:
   Jika bisnis mengizinkan mantan pengguna mendaftar kembali sebagai akun baru tanpa mendapatkan welcome coupon ganda, lakukan teknik anonymization pada nomor telepon tabel t_user saat status Removed aktif (contoh: 6282146627896_del_1730172526) dan catat SHA-256 hash nomor telepon di tabel blacklist kupon t_user_onboarding_history.

B. Rekomendasi untuk Tim Mobile (Flutter Developer):

1. Perjelas Navigasi Layar Login vs Sign Up:
   Pastikan pengguna yang berada di layar Login tidak memicu controller registrasi secara ambigu.
2. Penanganan Error Response DioException:
   Tangkap respons code: 500 dari backend dan lakukan translasi pesan ramah pengguna jika nomor berstatus Removed, bukan menampilkan mentah pesan 'This phone number is already registered' yang membingungkan calon pengguna.

7. LEMBAR PENGESAHAN INVESTIGASI QA

Peran	Nama Pejabat	Jabatan Resmi	Tanda Tangan & Tanggal
Disusun Oleh (QA)	Bhagus Arif Prayogo	Senior QA Automation Engineer	29 Okt 2026 (Verified)
Ditinjau Oleh (Dev)	Lead Backend Developer	Golang Architecture Team	_____
Disetujui Oleh (Mgmt)	Head of Engineering	Engineering & Product Lead	_____

** Dokumen ini diterbitkan secara otomatis dan terverifikasi oleh EVMoto QA Engineering Suite.*